

CYBER SECURITY TASK 2 — 2026

Phishing Detection & Awareness Report

Analysis of phishing email samples, risk classification, and organization-wide prevention guidelines.

Prepared for	Future Interns — Cyber Security Track
Prepared by	THOTA JANAKI RAMA KRISHNAMA NAIDU
Date	August 12, 2026
Classification	Internal — Security Awareness

1. Executive Summary

Phishing remains the leading initial-access technique used against organizations because it targets people rather than infrastructure. This report documents a hands-on analysis of representative phishing email samples, the indicators that expose them, and the risk-classification framework used to separate safe, suspicious, and confirmed-phishing messages.

Four sample emails were analyzed using header inspection, sender-domain verification, and link/URL review. Three were classified as phishing or suspicious; one legitimate-style email is included for contrast. Findings are translated into plain-language prevention guidance suitable for a non-technical audience, along with Do's and Don'ts for employees.

This exercise mirrors the process a Security Operations Center (SOC) analyst or security-awareness lead follows when triaging reported emails: verify the sender, inspect the headers, evaluate the links, and document the reasoning behind a risk rating.

2. Objective

The objective of this task is to:

- Analyze real-world-style phishing email samples the way a security analyst would.
- Identify and document the technical and psychological indicators that make an email suspicious or malicious.
- Apply a consistent risk classification (Safe / Suspicious / Phishing) to each sample.
- Explain each attack in plain, non-technical language.
- Produce prevention and awareness guidance that a business could distribute to employees.

This is a defensive, educational exercise. No malicious content was created, sent, or executed — all analysis was performed on inert, illustrative samples.

3. Tools & Methodology

3.1 Sources

Sample emails were modeled on common phishing patterns observed in publicly documented awareness datasets and real-world reporting, then reconstructed as illustrative examples for this analysis (no proprietary or personally identifiable data was used).

3.2 Analysis Tools

Indicator	What was observed	Why it's a red flag
Google Admin Toolbox Message Header	Parses raw email headers to reveal true originating server, SPF/DKIM/DMARC results, and routing path.	Confirms whether the sender's domain actually matches its claimed identity.
MxToolbox Email Header Analyzer	Cross-checks header authentication results and delivery path against known mail infrastructure.	Provides a second, independent read on authentication failures.
Browser address-bar / hover inspection	Manually reveals the true destination of a hyperlink before clicking, and checks domain structure.	Most fake login pages are caught at this step, not by visual inspection of the page.

3.3 Analysis Approach

- Step 1 — Read the visible email as a typical user would, noting first impressions (urgency, tone, requests).
- Step 2 — Inspect the sender's full email address, not just the display name.
- Step 3 — Review raw headers where available for SPF/DKIM/DMARC authentication results and originating IP/domain.
- Step 4 — Hover over (never click) all links to reveal actual destination URLs; check for domain look-alikes.
- Step 5 — Check for generic greetings, spelling/grammar irregularities, and mismatched branding.
- Step 6 — Apply the risk classification framework (Section 5) and document the reasoning.

4. Analyzed Email Samples

Four representative samples were analyzed below three phishing/suspicious eamples and one legitimate email included for contrast.

4.1 Sample 1 — Fake IT / Account Suspension Notice

RISK CLASSIFICATION: PHISHING

Email Exhibit

From	IT Support Desk <it-support@secure-office365-verify.com>
Subject	Action Required: Your mailbox will be suspended in 24 hours
Auth results	SPF: fail · DKIM: none · DMARC: fail

Body (excerpt)

Dear User,

We detected unusual sign-in activity on your account. To avoid permanent loss of access, verify your identity immediately:

<http://office365-login.verify-secure.net/auth>

Failure to verify within 24 hours will result in account suspension.

Thanks, The Microsoft Team

Indicators Identified

Indicator	What was observed	Why it's a red flag
Look-alike sender domain	"secure-office35-verify.com" instead of a Microsoft-owned domain	Mimics a trusted brand to bypass a quick visual check
Failed authentication	SPF and DMARC both fail on inspection	Confirms the message did not originate from a Microsoft mail server
Urgency / fear language	"24 hours," "permanent loss of access"	Designed to trigger a fast click before the user can verify
Mismatched link destination	Displayed link resolves to verify-secure.net, unrelated to Microsoft	The true destination is hidden until hovered or inspected
Generic sign-off	"The Microsoft Team" with no name, ticket number, or account detail	Legitimate account alerts usually reference specific account details

Plain-Language Explanation

This is a classic credential-harvesting attempt. It impersonates an IT/Microsoft notice and uses a false deadline to push the recipient toward a fake login page. Header authentication failures confirm the email did not come from Microsoft's real infrastructure.

4.2 Sample 2 — Business Email Compromise (Invoice Update)

Email Exhibit

From	David Chen (CFO) <d.chen@yourcompany-finance.com>
Subject	Updated banking details — please action before Friday's run
Auth results	SPF: pass (on a look-alike domain) · Reply-To: davidchen.cfo@proton-secure.mail

Body (excerpt)

Hi,

Our bank has updated its routing details ahead of Friday's payment run.

Please use the attached instructions for this cycle only and confirm once processed. I'm in back-to-back meetings so please don't call – email confirmation is fine.

– David

Indicators Identified

Indicator	What was observed	Why it's a red flag
Domain confusion	yourcompany-finance.com is a look-alike of the real corporate domain, not the domain itself	A one-word or hyphen addition is a common domain-spoofing technique
Mismatched reply-to	Replies route to an unrelated free email provider	Any response goes straight to the attacker, not the real executive
Discourages verification	"Please don't call"	Directly blocks the one step (phone verification) that would expose the scam
Off-cycle financial request	New banking details "for this cycle only"	Legitimate vendor/payroll changes go through a formal, auditable process — not a single email

Plain-Language Explanation

This is a Business Email Compromise (BEC) attempt. It impersonates a senior executive and pressures finance staff to redirect a real payment to an attacker-controlled account. The instruction to avoid a phone call is the clearest tell — it exists specifically to prevent verification.

4.3 Sample 3 — Fake Delivery Notification (Smishing-style)

RISK CLASSIFICATION: SUSPICIOUS

Email Exhibit

From	Delivery Notice <no-reply@parcel-tracking.com>
Subject	Your package could not be delivered — action needed
Auth results	SPF: fail · DKIM: fail

Body (excerpt)

Your package is on hold due to an incomplete address.

Update your delivery preferences here:

<http://parcel-tracking.com/update?id=88231>

A small redelivery fee (\$1.99) may apply.

Indicators Identified

Indicator	What was observed	Why it's a red flag
Typosquatted domain	"trackIng" uses a lowercase L in place of an I	Designed to look correct at a glance in a small mobile font
Small payment request	\$1.99 redelivery fee	Low amounts are used to lower the victim's guard and harvest card details
No specific carrier named	No reference to FedEx, UPS, USPS, DHL, etc.	Legitimate delivery notices always identify the actual carrier and a real tracking number

Plain-Language Explanation

This message is styled as a low-stakes, everyday notification, which is why it works — the small fee feels unimportant enough to enter card details without thinking. It is classified as Suspicious rather than Confirmed Phishing pending a look at the destination page, but the domain and authentication failures already justify treating it as unsafe.

4.4 Sample 4 — Legitimate Password Reset Confirmation

RISK CLASSIFICATION: SAFE

Email Exhibit

From	no-reply@github.com
Subject	Your GitHub password was changed
Auth results	SPF: pass · DKIM: pass · DMARC: pass

Body (excerpt)

Hi [username],

Your GitHub password was changed on Aug 10, 2026 at 14:02 UTC.

If this was you, no action is needed. If you did not make this change, secure your account: <https://github.com/settings/security>

Indicators Identified

Indicator	What was observed	Why it's a red flag
Domain matches exactly	Sender and link both resolve to github.com	No look-alike substitution or subdomain trickery
Full authentication pass	SPF, DKIM, and DMARC all pass	Confirms the message originated from GitHub's real mail servers
Specific, verifiable detail	Exact timestamp of the account change	Generic phishing templates rarely include accurate, specific account activity
No urgency or payment request	Purely informational, with an optional security link	No pressure tactic is used to force an immediate action

Plain-Language Explanation

This is included as a contrast case. It shares surface similarities with the phishing samples — an account-related subject line and a link to click — but passes every technical and behavioral check matching domain, full authentication, and no manipulative language.

5. Risk Classification Framework

Every reported or sampled email is assigned one of three ratings based on cumulative evidence rather than any single factor:

Rating	Criteria
Safe	Sender domain matches exactly; SPF/DKIM/DMARC all pass; no urgency, payment, or credential request; links resolve to the expected domain.
Suspicious	One or two irregularities present (e.g., minor domain irregularity, unexpected but plausible request) without conclusive evidence of malicious intent. Should be verified before acting.
Phishing	Multiple indicators present together: failed authentication, look-alike/mismatched domain, urgency or fear tactic, and a request for credentials, payment, or sensitive data.

Classification is always based on the combination of signals, not one factor in isolation — a failed SPF check alone can occur on legitimate misconfigured mail servers, and urgent language alone can appear in genuine business communication.

6. How the Attack Works (Plain-Language Summary)

Phishing succeeds by combining a technical disguise with a psychological trigger:

- Disguise — the email is made to look like it comes from a trusted source a bank, a colleague, IT, or a well-known brand, using a similar domain name or a spoofed display name.
- Trigger — the message creates urgency, fear, curiosity, or authority pressure ("your account will be locked," "the CEO needs this now," "you've won a prize") so the reader acts before thinking it through.
- Capture — the reader is directed to a fake login page, a malicious attachment, or asked to reply with sensitive information, handing the attacker credentials, payment details, or system access.
- Exploitation — the attacker uses the captured access or data for financial theft, further attacks inside the organization, or resale on criminal marketplaces.

The technology involved (spoofed headers, look-alike domains, cloned web pages) is only there to support that psychological trigger — which is why awareness and a habit of pausing before acting are more effective defenses than any single technical control.

7. Prevention & Awareness Guidelines

7.1 For Every Employee

- Hover over links before clicking to preview the real destination.
- Go directly to a known website or app instead of clicking a link in an email or text.
- Verify unusual requests — especially payments or credential changes — through a second channel (phone call to a known number, in person).
- Never reuse passwords across accounts; use a password manager.
- Enable multi-factor authentication (MFA) on every account that supports it.
- Report suspicious emails to the security/IT team rather than just deleting them.

7.2 Do's and Don'ts

Indicator	What was observed	Why it's a red flag
Do	Pause before clicking any link or attachment you weren't expecting.	Ten seconds of hesitation stops the vast majority of phishing clicks.
Do	Check the full sender address and hover over links before trusting them.	This is where most fakes are caught not in the visual design.
Do	Report suspicious emails to security/IT immediately.	Allows the same attack to be blocked before it reaches others.
Don't	Don't act on urgency alone, even from a "senior" sender.	Urgency is the single most common manipulation tactic in phishing.
Don't	Don't enter credentials on a page reached via an email link.	Always navigate directly or use a saved bookmark instead.
Don't	Don't assume HTTPS or a padlock icon proves legitimacy.	Attackers can obtain valid certificates for fake domains too.

8. Conclusion

This analysis reinforces a consistent pattern across all sampled phishing attempts technical red flags (domain mismatches, failed authentication) are almost always paired with a psychological trigger (urgency, authority, fear, or curiosity). Neither signal alone is always conclusive, but together they form a reliable basis for classification.

The strongest organizational defense is not a single tool but a habit pause, verify the sender and link independently of the message itself, and report anything uncertain. Combined with technical controls like SPF/DKIM/DMARC enforcement and MFA, consistent user awareness closes the gap that phishing is specifically designed to exploit.

Full email exhibits, indicator tables, and the risk classification framework in this report are intended for reuse in internal security-awareness training materials.